

# CASCADE CIVIC SYSTEMS, INC.

## System Security Plan (SSP)

### GrantBridge Grants Management Platform

FedRAMP Moderate Baseline | NIST SP 800-53 Rev. 5 | NIST RMF (SP 800-37 Rev. 2)  
Version 2.1 | Effective: 2026-03-01 | Prepared by: Chris Morrissey, ISSO  
Sample GRC portfolio artifact — fictional company and system

## 1. System Identification

|                           |                                                                                                      |
|---------------------------|------------------------------------------------------------------------------------------------------|
| System Name               | GrantBridge Grants Management Platform                                                               |
| System Abbreviation       | GRANTBRIDGE                                                                                          |
| Cloud Service Provider    | Cascade Civic Systems, Inc.                                                                          |
| Service Model             | Software as a Service (SaaS)                                                                         |
| Deployment Model          | Public Cloud (multi-tenant, logically isolated per agency)                                           |
| Authorization Path        | FedRAMP Agency ATO (sponsoring agency: U.S. Department of Community Development — fictional)         |
| Security Categorization   | FIPS 199 Moderate (see Section 3)                                                                    |
| Baseline Applied          | FedRAMP Moderate — 323 controls and enhancements                                                     |
| Underlying IaaS           | AWS GovCloud (US) — FedRAMP High P-ATO, inheritance documented in the Control Implementation Summary |
| Authorizing Official (AO) | Chief Information Officer, sponsoring agency                                                         |
| System Owner              | VP of Product, Cascade Civic Systems                                                                 |
| ISSO                      | Chris Morrissey                                                                                      |
| 3PAO                      | Independent Third-Party Assessment Organization (A2LA-accredited)                                    |

## 2. System Description and Purpose

GrantBridge is a multi-tenant Software-as-a-Service platform that enables federal, state, and local government agencies to administer the full grants lifecycle — opportunity publication, applicant intake, eligibility review, award issuance, subrecipient monitoring, financial drawdown, and closeout reporting.

The system processes application data submitted by grant applicants (including individuals and organizations), award and financial disbursement records, and subrecipient performance reporting. It does not process classified information. It does process Controlled Unclassified Information (CUI) and personally identifiable information (PII) belonging to individual applicants, including names, contact information, taxpayer identification numbers, and financial account details for disbursement.

### 2.1 User Roles

| Role                   | User Population            | Access Description                                                     |
|------------------------|----------------------------|------------------------------------------------------------------------|
| Agency Program Officer | Federal/state agency staff | Reviews applications, issues awards, monitors subrecipient performance |

|                          |                                 |                                                                                          |
|--------------------------|---------------------------------|------------------------------------------------------------------------------------------|
| Agency Administrator     | Federal/state agency staff      | Manages agency-level configuration, user provisioning, and reporting within their tenant |
| Applicant / Grantee      | External public users           | Submits applications, uploads supporting documents, files performance reports            |
| CSP Support Engineer     | Cascade Civic Systems personnel | Break-fix support; access is time-bound, approved, and session-recorded                  |
| CSP System Administrator | Cascade Civic Systems personnel | Privileged infrastructure access via bastion with phishing-resistant MFA                 |

### 3. FIPS 199 Security Categorization

The security categorization was determined in accordance with FIPS Publication 199 and NIST SP 800-60 Volume II, based on the information types processed by the system.

| Information Type (SP 800-60)                      | Confidentiality | Integrity | Availability |
|---------------------------------------------------|-----------------|-----------|--------------|
| C.2.8.12 — Grants Management                      | Moderate        | Moderate  | Moderate     |
| C.3.5.1 — Financial Disbursement / Payment        | Moderate        | Moderate  | Moderate     |
| C.2.8.9 — Personal Identity and Authentication    | Moderate        | Moderate  | Low          |
| C.3.4.1 — Reporting and Information Dissemination | Low             | Moderate  | Low          |

Applying the high water mark across all information types, the overall system security categorization is:

|                        |                                                                                                                                                                                                                                                                                        |
|------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Overall Categorization | MODERATE (Confidentiality: Moderate, Integrity: Moderate, Availability: Moderate)                                                                                                                                                                                                      |
| Rationale              | Unauthorized disclosure of applicant PII and financial account data would cause serious adverse effect on individuals; loss of integrity in award or disbursement records could result in improper payments; extended unavailability would disrupt statutorily deadlines grant cycles. |

### 4. Authorization Boundary

The authorization boundary encompasses all components of the GrantBridge platform that store, process, or transmit federal information, deployed within a dedicated AWS GovCloud (US) account managed exclusively by Cascade Civic Systems.

#### 4.1 Components Inside the Boundary

- Public-facing web application tier (containerized, behind AWS WAF and Application Load Balancer)
- Application API tier and asynchronous batch processing services
- Primary relational database (encrypted, multi-AZ, point-in-time recovery enabled)
- Document storage (S3 with customer-managed KMS encryption and object-level access logging)
- Identity provider integration layer supporting agency SSO (SAML/OIDC) and Login.gov for external applicants
- Logging, monitoring, and SIEM pipeline (CloudTrail, VPC Flow Logs, host and container telemetry)
- Bastion/jump host used for all privileged administrative access, with session recording

## 4.2 Components Outside the Boundary

- AWS GovCloud underlying infrastructure — physical, environmental, and hypervisor controls are inherited under the AWS FedRAMP High P-ATO
- Agency-side identity providers and agency endpoint devices — customer responsibility
- Cascade Civic Systems corporate IT (email, HR systems) — no federal data traverses these systems; corporate controls are documented as Service Provider Corporate origination

## 4.3 External Services and Interconnections

| External Service                | Data Exchanged                                      | Protection Mechanism                                                                                               |
|---------------------------------|-----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| Login.gov                       | Applicant authentication assertions                 | SAML 2.0 over TLS 1.2+; no credentials stored by GrantBridge; FedRAMP-authorized service                           |
| U.S. Treasury Payment Interface | Disbursement instruction files                      | Mutual TLS with certificate pinning; files encrypted at rest prior to transmission; SFTP over dedicated connection |
| SAM.gov API                     | Entity registration and exclusion status validation | TLS 1.2+; read-only; API key stored in AWS Secrets Manager                                                         |

## 5. Control Implementation Approach

Control implementations are documented in full in the accompanying Security Controls Traceability Matrix (SCTM). Each control is assigned an implementation status and a control origination, which establishes accountability across the shared responsibility model.

| Control Origination              | Definition                                                                                                                                                                             |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Service Provider Corporate       | Control is implemented organization-wide by Cascade Civic Systems and applies to all systems (e.g., personnel screening, security awareness training)                                  |
| Service Provider System-Specific | Control is implemented uniquely for the GrantBridge system (e.g., boundary protection, audit event selection)                                                                          |
| Inherited                        | Control is fully inherited from AWS GovCloud under its FedRAMP High P-ATO (e.g., physical access control, media sanitization)                                                          |
| Shared                           | Responsibility is divided between Cascade Civic Systems and the customer agency (e.g., account management, where the CSP provides capability and the agency administers its own users) |
| Customer (Configured)            | Control must be configured by the customer agency; described in the Customer Responsibility Matrix                                                                                     |

As of the current assessment, 20 of 30 sampled controls are fully Implemented, 8 are Partially Implemented with corresponding POA&M items, and 2 are fully Inherited. Deficiencies are tracked to closure in the Plan of Action and Milestones.

## 6. Continuous Monitoring Strategy

Cascade Civic Systems maintains an ongoing authorization posture through a documented continuous monitoring program aligned to the FedRAMP Continuous Monitoring Strategy Guide.

| Activity                    | Frequency | Deliverable / Evidence                               |
|-----------------------------|-----------|------------------------------------------------------|
| Authenticated vulnerability | Monthly   | Raw scan results and remediation status submitted to |

|                                         |                        |                                                                    |
|-----------------------------------------|------------------------|--------------------------------------------------------------------|
| scanning (OS, web, database, container) |                        | the AO                                                             |
| POA&M update and submission             | Monthly                | Updated POA&M with milestone progress and closures                 |
| System inventory reconciliation         | Monthly                | Updated integrated inventory workbook                              |
| Configuration drift detection           | Continuous (automated) | AWS Config compliance reports and remediation records              |
| Audit log review                        | Weekly                 | Ticketed review record with reviewer, findings, and escalations    |
| Annual security assessment (3PAO)       | Annually               | Security Assessment Report (SAR) and updated SSP                   |
| Contingency plan test                   | Annually               | After-action report with measured RTO/RPO                          |
| Incident response tabletop              | Annually               | Exercise report and updated IR Plan                                |
| Significant change request              | As needed              | Significant Change Request submitted to AO prior to implementation |

## 7. Incident Response and Reporting

Security incidents are handled per the GrantBridge Incident Response Plan, which defines severity tiers, escalation paths, and a 24x7 on-call rotation. Consistent with FedRAMP requirements, confirmed or suspected incidents involving federal information are reported to US-CERT and to the sponsoring agency ISSO within one hour of determination. Incident records are retained and reviewed during the annual assessment.

## 8. Roles and Responsibilities

| Role                                       | Responsibility                                                                                                                         |
|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| Authorizing Official (AO)                  | Accepts residual risk on behalf of the agency and issues the Authority to Operate                                                      |
| Information System Security Officer (ISSO) | Maintains the SSP and POA&M; coordinates continuous monitoring deliverables; serves as the primary security point of contact to the AO |
| System Owner                               | Accountable for overall system operation, budget, and security posture                                                                 |
| Third-Party Assessment Organization (3PAO) | Performs independent security control assessment and produces the SAR                                                                  |
| Security Operations                        | Executes monitoring, detection, and incident response activities                                                                       |
| Platform Engineering                       | Implements and maintains technical controls; performs remediation                                                                      |

## 9. Related Documentation

- Security Controls Traceability Matrix (SCTM) — control-by-control implementation and assessment results
- Security Assessment Report (SAR) — independent assessment findings and risk determinations
- Plan of Action and Milestones (POA&M) — tracked remediation of identified weaknesses
- Contingency Plan, Incident Response Plan, and Configuration Management Plan — maintained separately and referenced by their respective control families

# 10. Document Revision History

| Version | Date       | Author             | Summary of Changes                                                                                         |
|---------|------------|--------------------|------------------------------------------------------------------------------------------------------------|
| 1.0     | 2025-08-01 | C. Morrissey, ISSO | Initial SSP issuance for FedRAMP Moderate authorization                                                    |
| 2.0     | 2026-01-15 | C. Morrissey, ISSO | Updated authorization boundary following Login.gov integration; added external interconnection detail      |
| 2.1     | 2026-03-01 | C. Morrissey, ISSO | Incorporated 3PAO assessment results; updated control implementation statuses and linked POA&M identifiers |